

PEC1 (Arquitectura de bases de datos)



TúNombre TúNombre TúApellido TúApellid

Arquitectura de bases de datos

04/12/2025

Índice

Índice.....	1
Pregunta 1 (3 puntos).....	2
Enunciado.....	2
Respuesta 1 (3 puntos).....	3
EXPLICACIÓN DE LA ESTRATEGIA DE FRAGMENTACIÓN.....	3
EVALUACIÓN DEL GRADO DE CORRECCIÓN.....	4
ASPECTOS CORRECTOS:.....	4
PROBLEMAS DETECTADOS:.....	4
RESUMEN.....	4
Pregunta 2 (2 puntos).....	5
Enunciado.....	5
Cuestiones:.....	5
Respuesta 2 (2 puntos).....	5
MEDIDAS PARA CUMPLIR EL RGPD Y GARANTIZAR CONFIDENCIALIDAD, INTEGRIDAD Y DISPONIBILIDAD.....	5
Principios del RGPD y medidas aplicables.....	5
Licitud, lealtad y transparencia.....	5
Limitación de la finalidad.....	6
Minimización de datos.....	6
Exactitud.....	6
Limitación del plazo de conservación.....	6
Integridad y confidencialidad.....	6
Responsabilidad proactiva (accountability).....	6
Medidas específicas de seguridad.....	6
Confidencialidad.....	6
Integridad.....	7
Disponibilidad.....	7
Notificación de brechas de seguridad.....	7
Derechos de los interesados.....	7
Transferencias internacionales.....	7
DATOS DE CATEGORÍA ESPECIAL Y TRATAMIENTO LÍCITO.....	7
Datos de categoría especial (Art. 9 RGPD).....	7
Aplicación en RentUOC.....	7
Condiciones para un tratamiento lícito.....	7
Consentimiento explícito, específico e informado.....	8
EVALUACIÓN DE IMPACTO RELATIVA A LA PROTECCIÓN DE DATOS (EIPD / DPIA).....	8
Cuándo es obligatoria.....	8
Aplicación a RentUOC — Reconocimiento facial.....	8
FUENTES CONSULTADAS.....	9

Pregunta 1 (3 puntos)

Enunciado

La base de datos **RentUOC**, dedicada al alquiler de vehículos, está formada por las siguientes relaciones (claves primarias subrayadas). A menos que se diga lo contrario, todos los atributos son obligatorios (no admiten valores nulos).

```
Vehicle (licensePlate, brand, model, hp, fuel, year)
Customer (nif, name, surname, email, phone)
Employee (nif, fullname, position, phone)
Rental (id, vehicleId, customerId, employeeId, startDate, endDate, price)
    {vehicleId} es clave ajena que referencia {licensePlate} Vehicle
    {customerId} es clave ajena que referencia {nif} Customer
    {employeeId} es clave ajena que referencia {nif} Employee
Evaluation (rentalId, rating, comments)
    {rentalId} es clave ajena que referencia {id} Rental
```

- La relación **Vehicle** tiene la información de los vehículos disponibles para alquilar, incluyendo matrícula, marca, modelo, potencia, tipo de combustible y año de fabricación.
- La relación **Customer**, tiene los distintos clientes que alquilan los vehículos, incluyendo NIF, nombre, apellidos, email y teléfono.
- La relación **Employee** contiene los distintos empleados que gestionan los alquileres, donde position indica su puesto (pudiendo ser "Manager" o "Agent").
- La relación **Rental** registra los alquileres realizados, indicando qué vehículo fue alquilado, por qué cliente, qué empleado gestionó el alquiler, la fecha de inicio y fin del alquiler, y el precio.
- La relación **Evaluation** contiene las valoraciones de los alquileres realizadas por los clientes, indicando el identificador del alquiler, la puntuación (rating) y comentarios.

Se decide aplicar la siguiente estrategia de fragmentación:

C1 = Customer [nif, name, surname, phone]

C2 = Customer [nif, name, surname, email]

V1 = Vehicle (hp > 150)

V2 = Vehicle (hp <= 150)

E1 = Employee [nif, fullName, position] (position = "Manager")

E2 = Employee [nif, phone] (position = "Agent")

R1 = Rental V1

R2 = Rental V2

EV1 = Evaluation (rating < 5)

EV2 = Evaluation (rating = 5)

EV3 = Evaluation (rating > 5)

Se pide explicar la estrategia de fragmentación de las distintas relaciones, así como evaluar su grado de corrección.

Respuesta 1 (3 puntos)

Una de las cosas más difíciles para mí durante mis estudios ha sido el diseño y creación de bases de datos (difícil no significa que no me guste), luego de analizar con calma la propuesta he dividido mi respuesta en los siguientes puntos:

EXPLICACIÓN DE LA ESTRATEGIA DE FRAGMENTACIÓN

1. CUSTOMER: Fragmentación VERTICAL.

- a. C1 = Customer [nif, name, surname, phone].
- b. C2 = Customer [nif, name, surname, email].

Separación de datos de contacto (teléfono vs email) manteniendo la clave primaria para reconstrucción.

2. VEHICLE: Fragmentación HORIZONTAL.

- a. V1 = Vehicle (hp > 150).
- b. V2 = Vehicle (hp <= 150).

División por potencia: vehículos de alta potencia vs estándar. Condiciones disjuntas y completas.

3. EMPLOYEE: Fragmentación MIXTA (Horizontal + Vertical).

- a. E1 = Employee [nif, fullName, position] (position = "Manager").
- b. E2 = Employee [nif, phone] (position = "Agent").

Combina fragmentación horizontal (por position) y vertical (atributos diferentes según rol).

4. RENTAL: Fragmentación HORIZONTAL DERIVADA.

- a. R1 = Rental V1 (alquileres de vehículos hp > 150).
- b. R2 = Rental V2 (alquileres de vehículos hp <= 150).

Se deriva de la fragmentación de Vehicle para mantener localidad de datos.

5. EVALUATION: Fragmentación HORIZONTAL.

- a. EV1 = Evaluation (rating < 5).
- b. EV2 = Evaluation (rating = 5).

c. **EV3 = Evaluation (rating > 5).**

Aquí hay un análisis más profundo, porque la condición **EV3** ("rating mayor a 5") es problemática porque asume un dominio de rating que no está especificado. Si el rating va de 1-5 (escala típica), **EV3** siempre estará vacío, violando el principio de completitud. Si el rating va de 1-10, la fragmentación no cubre el rango 1-4, violando también la completitud.

EVALUACIÓN DEL GRADO DE CORRECCIÓN

ASPECTOS CORRECTOS:

- **Vehicle:** Fragmentación disjunta y completa ("hp > 150" y "hp <= 150") cubren todos los casos).
- **Customer:** Fragmentación vertical correcta, ambos fragmentos incluyen clave primaria.
- **Employee:** Fragmentación mixta bien aplicada, condiciones completas (Manager y Agent).
- **Rental:** Fragmentación derivada consistente con Vehicle, mantiene integridad referencial.

PROBLEMAS DETECTADOS:

1. **Evaluation:** La condición **EV3** ("rating > 5") es problemática. Si rating va de "1-5", **EV3** siempre estará vacío. Si el rating va de "1-10", la fragmentación no cubre el rango "1-4". Se debe clarificar el dominio del rating y ajustar las condiciones para que sean disjuntas y completas.
2. **Employee:** **E2** solo contiene "[nif, phone]", lo que puede ser intencional para optimización, pero limita consultas que requieran información completa de agents, pero, una vez más, para optimización, es una excelente auxiliar.
3. **Customer:** Redundancia controlada: los atributos name y surname están duplicados en ambos fragmentos, lo cual es necesario para la reconstrucción mediante JOIN, aunque genera redundancia.

RESUMEN

La estrategia es mayormente correcta. Cuatro de las cinco fragmentaciones (Customer, Vehicle, Employee y Rental) están correctamente implementadas siguiendo los principios de completitud, disyunción y reconstrucción. El principal problema está en Evaluation, donde la condición EV3 (rating > 5) puede ser incorrecta dependiendo del dominio de rating, lo que afecta la completitud de la fragmentación, en general, de cinco soluciones, cuatro están bastante bien hechas y la quinta parcialmente, me atrevo a decir en base a eso que la solución está en un 85%.

Pregunta 2 (2 puntos)

Enunciado

Siguiendo con nuestra empresa RentUOC, que gestiona la información de sus clientes, empleados y vehículos a través de un sistema informático, cuenta con un portal web donde los clientes pueden realizar la reserva, consultar las facturas y enviar las valoraciones. Así como los empleados pueden acceder con sus credenciales para gestionar las operaciones. RentUOC debe asegurarse de que cumple con el Reglamento General de Protección de Datos (RGPD) y con la Ley Orgánica 3/2018 (LOPDGDD) en tratamiento de toda la información.

Cuestiones:

- Los reglamentos de protección de datos establecen una serie de principios que deben respetarse en todo tratamiento de información personal. Describe las medidas que RentUOC debería aplicar en su sistema para cumplir con esos principios y garantizar la confidencialidad, integridad y disponibilidad de los datos.
- Determina qué datos se consideran de categoría especial según la legislación vigente, y explica brevemente qué condiciones o excepciones permiten su tratamiento lícito.
- RentUOC planea incorporar nuevas funcionalidades en su portal web, como el reconocimiento facial para identificar a los clientes frecuentes al recoger el vehículo. Explica qué es una Evaluación de Impacto relativa a la Protección de Datos (EIPD) y en qué casos es obligatoria según el RGPD.

Nota: la respuesta a este ejercicio no debe superar la extensión de tres páginas y es necesario incluir las fuentes consultadas.

Respuesta 2 (2 puntos)

MEDIDAS PARA CUMPLIR EL RGPD Y GARANTIZAR CONFIDENCIALIDAD, INTEGRIDAD Y DISPONIBILIDAD

Principios del RGPD y medidas aplicables

Licitud, lealtad y transparencia

- Informar claramente de finalidades, base jurídica, destinatarios y derechos mediante una Política de Privacidad accesible.
- Obtener consentimiento informado cuando sea necesario.
- Garantizar una base legal adecuada para cada tratamiento (contrato, obligación legal, consentimiento, etc.).

Limitación de la finalidad

- Definir y documentar finalidades específicas.
- No usar los datos para fines incompatibles sin nueva base legal (ej.: marketing sin consentimiento).

Minimización de datos

- Recoger sólo los datos imprescindibles.
- Revisar y eliminar información no necesaria.

Exactitud

- Permitir una rectificación sencilla por parte del interesado.
- Validar y actualizar periódicamente los datos.

Limitación del plazo de conservación

- Definir plazos según normativa aplicable (ej.: documentación fiscal 4–6 años).
- Establecer procesos de eliminación o anonimización automática.

Integridad y confidencialidad

- Cifrado en tránsito (TLS 1.3) y en reposo (AES-256).
- Control de acceso basado en roles y autenticación multifactor para empleados.
- Políticas de contraseñas robustas, registro de accesos y auditorías periódicas.
- Copias de seguridad verificadas y segmentación de redes.

Responsabilidad proactiva (accountability)

- Mantener actualizado el Registro de Actividades de Tratamiento.
- Firmar contratos Art. 28 con proveedores (encargados del tratamiento).
- Realizar formaciones periódicas y auditorías internas.

Medidas específicas de seguridad

Confidencialidad

- Acuerdos de confidencialidad con empleados.
- Gestión segura de claves y acceso limitado a datos sensibles.

Integridad

Validación de entrada de datos, logs de modificaciones y transacciones ACID. Hashing y firmas digitales en procesos críticos.

Disponibilidad

Servidores redundantes, monitorización 24/7, protección DDoS. Plan de continuidad de negocio y recuperación ante desastres.

Notificación de brechas de seguridad

Notificar a la AEPD en un máximo de 72 horas si existe riesgo para los derechos de los interesados. Notificar directamente al afectado en casos de alto riesgo. Mantener un Plan de Respuesta a Incidentes documentado.

Derechos de los interesados

Garantizar acceso, rectificación, supresión, oposición, portabilidad, limitación y no ser objeto de decisiones automatizadas. Plazo de respuesta: 1 mes.

Transferencias internacionales

Si se usan servicios fuera del EEE, aplicar garantías: Cláusulas Contractuales Tipo, BCR o decisiones de adecuación.

DATOS DE CATEGORÍA ESPECIAL Y TRATAMIENTO LÍCITO

Datos de categoría especial (Art. 9 RGPD)

Incluyen origen étnico, opiniones políticas, religión, afiliación sindical, salud, datos biométricos para identificar de manera unívoca, genética, orientación sexual.

Aplicación en RentUOC

Pueden considerarse categorías especiales tales como reconocimiento facial para identificar clientes (datos biométricos), datos de accesibilidad/discapacidad (datos de salud). Los datos de localización no son categoría especial, pero sí altamente sensibles.

Condiciones para un tratamiento lícito

El tratamiento está prohibido salvo en las excepciones del **Art. 9.2**, destacando para RentUOC los siguientes escenarios:

- Consentimiento explícito (clave para biometría).
- Ejercicio de reclamaciones.
- Interés público esencial (no aplicable habitualmente).
- Finalidades de salud (solo para empleados y supuestos muy concretos).

Consentimiento explícito, específico e informado.

- Alternativa no biométrica igualmente válida (**tarjeta, PIN, verificación manual**).
- Cifrado reforzado y acceso restringido.
- Minimización estricta y conservación mínima necesaria.
- Obligación de realizar una **EIPD**.

EVALUACIÓN DE IMPACTO RELATIVA A LA PROTECCIÓN DE DATOS (EIPD / DPIA)

La **EIPD** es un análisis previo que identifica y mitiga riesgos antes de iniciar tratamientos que pueden suponer alto riesgo (**Art. 35 RGPD**), el contenido mínimo de una **EIPD** es el siguiente:

- Descripción del tratamiento, finalidad y base legal.
- Necesidad y proporcionalidad.
- Identificación de riesgos para los interesados.
- Medidas para mitigarlos.
- Consulta a la **AEPD** si persisten riesgos altos.

Cuándo es obligatoria

Lo es y lo será en todos aquellos escenarios en los que exista alguno de los siguientes motivos o causas:

- Evaluación sistemática de personas mediante decisiones automatizadas.
- Tratamiento a gran escala de datos de categoría especial.
- Vigilancia sistemática de zonas de acceso público.
- Uso de tecnologías que puedan generar riesgos significativos.

Aplicación a RentUOC – Reconocimiento facial

Debe realizarse una **EIPD** porque:

- Se tratan datos biométricos (categoría especial).
- Es una tecnología potencialmente intrusiva.
- Implica identificación sistemática de individuos.

- Puede afectar gravemente a los derechos de los interesados (riesgo de identificación errónea, usos no previstos o accesos indebidos).

FUENTES CONSULTADAS

- [Reglamento \(UE\) 2016/679 \(RGPD\)](#).
- [Ley Orgánica 3/2018 \(LOPDGDD\)](#).
- [Agencia Española de Protección de Datos \(AEPD\) – Guías sobre EIPD, consentimiento y seguridad](#).
- [Guía sobre el consentimiento de la AEPD](#).
- [Guías de seguridad de la AEPD](#).
- [European Data Protection Board \(EDPB\) – Directrices sobre DPIA y datos biométricos](#).

Pregunta 3 (3 puntos)

Enunciado

Sandra es la propietaria de la tabla Employee (nif, fullName, position, phone) y Vehicle (licensePlate, brand, model, hp, fuel, year). En la empresa también tenemos los usuarios Lorenzo, Vicente, May, Rafael y Elena, y se asignan los siguientes permisos a estos trabajadores para que puedan trabajar.

Permisos a otorgar:

1. Sandra asigna permisos de consulta sobre la tabla Employee al usuario Rafael, con la opción de poder delegar ese permiso. Además, asigna los permisos de modificación sobre phone a May y permisos de borrado sobre toda la tabla a Lorenzo.
2. Rafael asigna permisos de modificación sobre el atributo position de Employee a Vicente y da permisos de consulta sobre toda la tabla a Elena, pudiendo este último delegar dicho permiso.
3. May concede permisos de consulta sobre Employee a Vicente, y permisos de borrado sobre phone a Elena.
4. Lorenzo concede permisos de borrado sobre la tabla Employee a Rafael.
5. Sandra asigna permisos de consulta y modificación sobre la tabla Vehicle a Elena, con posibilidad de delegar. Además, asigna permisos de modificación sobre los campos hp y year a May, con opción de delegar. Y también asigna permisos de borrado sobre toda la tabla Vehicle a Lorenzo.
6. Vicente asigna permisos de consulta sobre Vehicle a Rafael.
7. Elena concede permisos de modificación sobre el campo fuel a May, y de consulta sobre Employee a Vicente.
8. May asigna permisos de modificación sobre el atributo fuel de la tabla Vehicle a Rafael.

Se pide responder a las siguientes cuestiones justificando las respuestas que lo requieran:

- a) Proponed las sentencias SQL de autorizaciones que se tendrían que realizar para cada uno de los 7 puntos descritos anteriormente (indicando que usuario de los descritos anteriormente lanzaría las sentencias). Si alguna sentencia no se pudiera realizar correctamente, deberéis escribir la sentencia e indicar el motivo por el que no se puede realizar. Cuando una sentencia no se puede realizar se continúa con la siguiente, no se para el flujo, aunque sí que influirá para realizar las siguientes asignaciones. Sandra, como propietario de las tablas, tendrá todos los permisos inicialmente y el resto solamente el permiso CONNECT. También podéis considerar que se han creado los sinónimos necesarios para poder acceder a las tablas sin tener que indicar el esquema del usuario Sandra. Es decir, se podría acceder indicando Employee en lugar de, por ejemplo, Sandra.Employee.
- b) Dibujar el grafo/esquema de autorizaciones válidas.
- c) Supón que Rafael eliminó los permisos que había dado al usuario Elena. Además, Sandra concede permisos de consulta sobre Vehicle a Rafael. Escribid las sentencias y redibujar el grafo final.
- d) Sandra quiere que Vicente pueda consultar todos los campos de Employee, a excepción del campo phone. ¿Qué debería hacerse en este caso? Pon las sentencias necesarias para que

Respuesta 3 (3 puntos)

a) Sentencias SQL para autorizaciones

Punto N.º1

Objetivo	Consulta
Sandra asigna permisos de consulta sobre la tabla Employee al usuario Rafael	GRANT SELECT ON Employee TO Rafael WITH GRANT OPTION;
Sandra asigna permisos de modificación sobre phone a May	GRANT UPDATE (phone) ON Employee TO MAY;
Sandra asigna permisos de borrado sobre toda la tabla a Lorenzo	GRANT DELETE ON Employee TO Lorenzo;

En este escenario no hay ningún problema porque Sandra es la propietaria de Employee y por lo tanto tiene todos los permisos necesarios para las autorizaciones.

Punto N.º2

Objetivo	Consulta
Rafael asigna permisos de modificación en position a Vicente	GRANT UPDATE (position) ON Employee TO Vicente;
Rafael asigna permisos de consulta sobre Employee a Elena (pudiendo delegar)	GRANT SELECT ON Employee TO Elena WITH GRANT OPTION;

Aquí ocurre que **Rafael solo tiene permisos de select sobre employee** con opción de delegar, pero no tiene permisos de **update**, por lo tanto, no puede asignarle permisos de modificación a Vicente pero sí que puede asignarle permisos de **select** a Elena.

Punto N.º3

Objetivo	Consulta
May concede permisos de consulta sobre Employee a Vicente	GRANT SELECT ON Employee TO VICENTE;
May concede permisos de borrado sobre "phone" a Elena	GRANT DELENTE (phone) ON Employee TO Elena;

May anteriormente fue dado el permiso de **update** sobre **phone** pero no el de **delete**, por lo tanto no se puede dar permisos a Elena, tampoco pudiendo dar permisos a Vicente.

Punto N.º4

Objetivo	Consulta
Lorenzo concede permisos de borrado sobre la tabla Employee a Rafael	GRANT DELETE ON Employee TO Rafael;

Si bien **Lorenzo** tiene permisos de **delete** sobre employee en las autorizaciones no se utilizó **GRANT OPTION**, por lo tanto, no puede delegar y no puede conceder permisos a nadie.

Punto N.º5

Objetivo	Consulta
Sandra asigna permisos de consulta y modificación (ambos) sobre Vehicle a Elena, con posibilidad de delegar.	GRANT SELECT, UPDATE ON Vehicle TO Elena WITH GRANT OPTION;
Sandra asigna permisos de modificación sobre hp y year a May, con opción de delegar.	GRANT UPDATE (hp, year) ON VEHICLE TO May WITH GRANT OPTION;
Sandra asigna permisos de borrado sobre toda la tabla Vehicle a Lorenzo	GRANT DELETE ON Vehicle TO Lorenzo;

Una vez más, Sangre es propietaria, por lo tanto, tiene todo el poder absoluto de conceder todos los permisos, todas las consultas funcionan.

Punto N.º6

Objetivo	Consulta
Vicente asigna permisos de consulta sobre Vehicle a Rafael	GRANT SELECT ON Vehicle TO Rafael;

No se puede ejecutar, **Rafael** no tiene la capacidad de dar permiso de este tipo a ningún usuario pues él mismo no los posee.

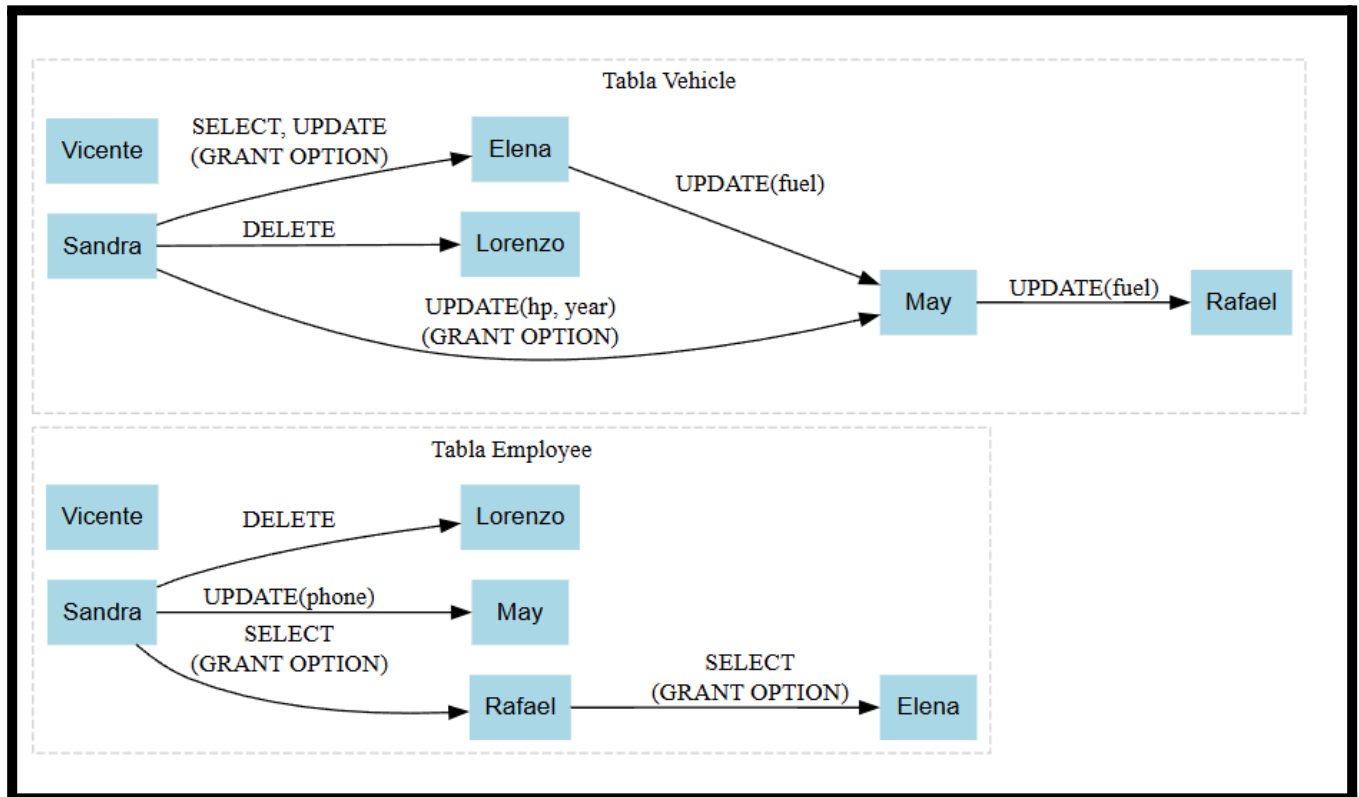
Punto N.º7

Objetivo	Consulta
Elena concede permisos de modificación sobre fuel a May	GRANT UPDATE (fuel) ON Vehicle TO May;
Elena concede permisos de consulta sobre Employee a Vicente	GRANT SELECT ON Employee TO VICENTE;
May asigna permisos de modificación sobre fuel de Vehicle a Rafael	GRANT UPDATE (fuel) ON Vehicle TO Rafael;

Elena tiene **update** con **GRAN OPTION** sobre **vehicle** así que perfectamente puede darle los permisos a **May**, sin embargo, no tiene permisos de **select** sobre **Employee** por lo tanto la segunda consulta no funciona, la tercera, igual que la primera, funciona, si le da permisos de modificación a Rafael.

b) Grafo de autorizaciones inicial

Utilizando las consultas y mi entendimiento sobre ellas pude aplicar un poco de IA (específicamente **ChatGPT4**) para generar un grafo de forma automatica editable desde la URL <https://dreampuf.github.io/GraphvizOnline/>.

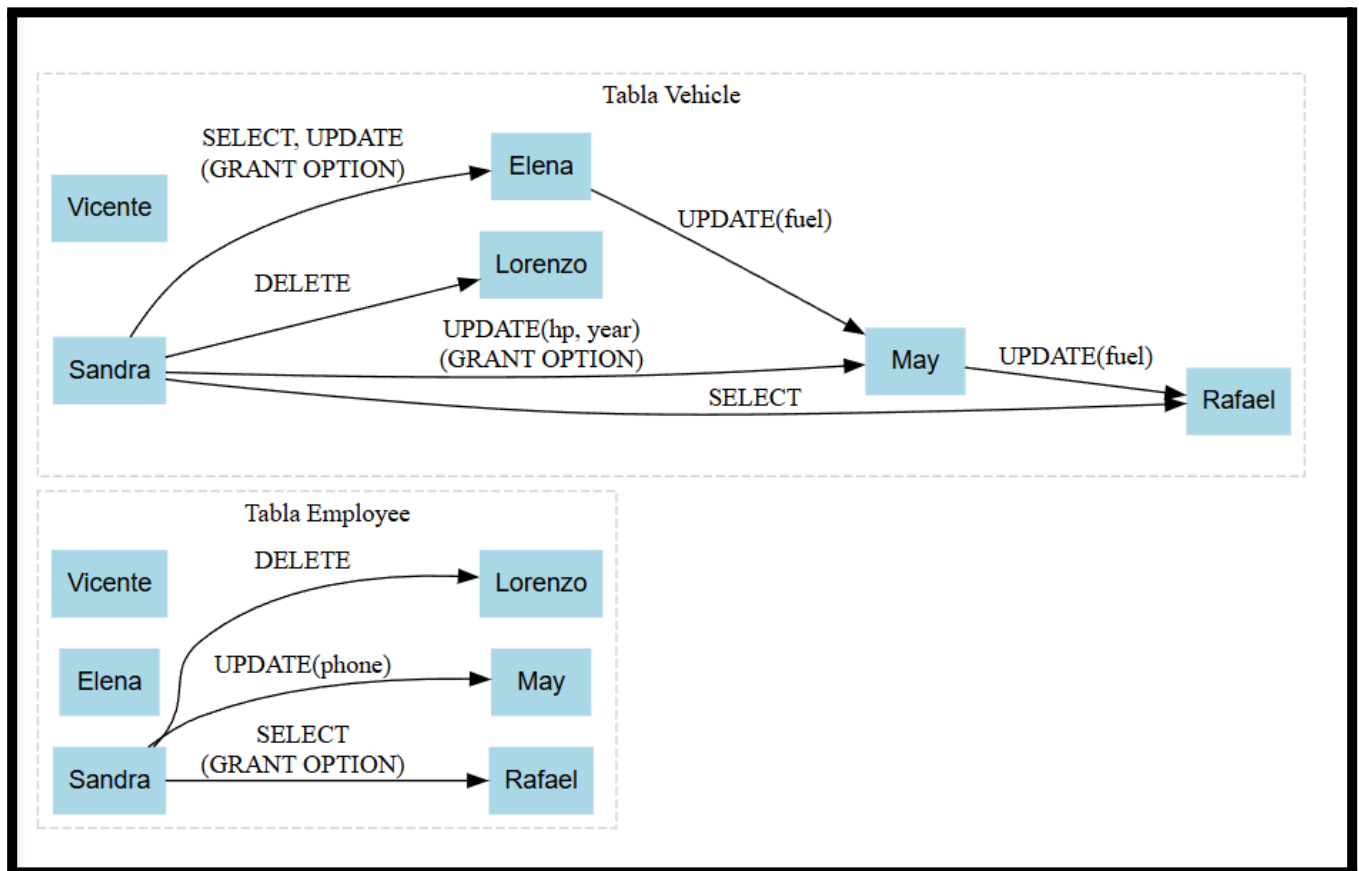


Vicente fue el único empleado que, sin importar los intentos, no recibió ningún tipo de permisos porque ninguna de las autorizaciones fue válida, por eso aparece, porque es un sujeto/personaje que forma parte del enunciado aunque no tiene permisos.

c) Modificaciones de Rafael (eliminación de permisos)

Objetivo	Consulta
Rafael elimina todos los permisos que había concedido Elena	REVOKE SELECT ON Employee FROM Elena;
Sandra concede permisos de consulta sobre Vehicle a Rafael.	GRANT SELECT ON Vehicle TO Rafael;

Después de estas modificaciones podemos hacer seguimiento visual repintando el grafo con estos nuevos cambios.



d) Consulta de vicente de todos los campos de Employee excepto phone

Oracle SQL no permite la negación de columnas en bases de datos en **GRANT**, por lo tanto, la forma correcta sería crear una vista que excluya a **phone** y que esta vista tenga **select**, la consulta probablemente se vería así:

```
CREATE VIEW Employeee_without_phone AS SELECT nif, fullName, position FROM Employee;
GRANT SELECT ON Employee_without_phone TO Vicensete;
```

De esta forma se superan las limitaciones de **Oracle SQL** y **Vicente** puede consultar todos los campos de **Employee** exceptuando **phone**.

Pregunta 4 (2 puntos)

Enunciado

Para la realización de esta pregunta, será necesaria la visualización del siguiente video relacionado con algunos de los modelos de seguridad que pudimos ver en el módulo 4.

 **Role-based access control (RBAC) vs. Attribute-based access control (ABAC)**

- a) Explica los modelos RBAC y ABAC que se pueden ver en el vídeo, indicando alguna ventaja y desventaja de ellos.
- b) En RentUOC, los empleados con cargo Manager (May y Elena) pueden ver y modificar los datos de los vehículos, mientras que los que tienen el cargo Agent (Rafael y Vicente) solo pueden consultarlos. El administrador decide aplicar un control del acceso basado en roles. Escribe las sentencias SQL necesarias para que los usuarios mencionados puedan realizar lo que se indica según su cargo y el control de acceso aplicado.
- c) Supón que en RentUOC, tenemos 25 empleados, donde varios de ellos cambian de puesto con frecuencia (de Agent a Manager, de Manager a Auditor, etc.). Compara brevemente cómo se gestionaría esta situación bajo un sistema sin roles (asignando permisos usuario por usuario) frente a un sistema RBA. Analiza ventajas RBA, posibles problemas sin y consecuencias sobre la seguridad sin RBA.
- d) RentUOC desea aplicar una política donde un empleado solo pueda acceder a los alquileres (Rental) de su misma sucursal (nuevo campo branch en Rental y Employee) y durante su horario laboral (8:30–18:00). ¿Qué modelo de control de acceso sería el más adecuado? Justifica la respuesta.

Respuesta 4 (2 puntos)

Explicación de los modelos de seguridad

Modelo RBAC (Role-Based-Access-Control)

Definición

En este modelo, los permisos no se asignan directamente a los usuarios, sino a roles (**por ejemplo, Manager, Agent**). Los usuarios se asocian a uno o varios roles y heredan automáticamente los permisos asignados a dichos roles.

Ventajas

Entiendo que en empresas grandes es un buen sistema porque permite crear mejores organización, crear una mejor jerarquía y heredar/propagar los permisos cuando se crea conveniente, aunque en empresas medianas/pequeñas puede ser agregar sobre complejidad a un sistema de datos.

Desventajas

Es muy rígido y robusto, es una ventaja pero al mismo tiempo una desventaja porque si los roles y/o sus permisos dependen de variables muy cambiantes como horarios, sucursal, tipo de proyecto o proyecto en específico se vuelve poco flexible y difícil de mantener.

Modelo ABAC (Attribute-Based-Access-Control)

Definición

A diferencia del anterior, aquí no se usan roles para la asignación de permisos, si no atributos directos a los usuarios, por ejemplo, en **RBAC** podrían haber roles como **Manager** el cual tuviese permisos de **SELECT, UPDATE** en **Vehicle**, pero, por otra parte en **ABAC** podría ser algo condicional como “**usuario.branch = vehicle.branch**” y la hora es de entre las 9AM y las 15PM entonces tiene permisos de “X” tipo en esa brecha.

Ventajas

Es muy flexible, precisamente porque permite controlar con muchos argumentos los accesos, “X” usuario solo puede acceder si “X” y “Y” condiciones se cumplen (estar dentro de cierto horario, realizar solo ciertas operaciones, solo en ciertos contextos).

Desventajas

Si el anterior era robusto y rígido este es aún más difícil de implementar, creo que depende mucho del contexto de la empresa, si los datos necesitan ser muy seguros y muy controlados este sistema sería el óptimo pero es mucho más difícil de implementar.

Sentencias SQL para RBAC (Manager vs Agent)

Bueno, crearemos dos roles de ejemplo, uno de ellos será por ejemplo **manager** y el otro será **agent**, la secuencia de sentencias/consultas sería la siguiente:

```
CREATE ROLE Manager;  
CREATE ROLE Auditor;
```

```
GRANT SELECT, UPDATE ON Vehicle TO Manager;  
GRANT SELECT ON Vehicle TO Auditor;
```

```
GRANT Manager TO May;  
GRANT Manager TO Elena;  
GRANT Auditor TO Rafael;  
GRANT Auditor TO Vicente;
```

Con esta simple secuencia de consultas no solo creamos roles reutilizables, modificables y asignables, si no que en pocas lineas hemos dado permisos a **May** y **Elena** de **select** y **update** la tabla **Vehicles** mientras que **Rafael** y **Vicente** solo tienen permisos de **select**.

Comparación de un sistema con roles y sin roles

Escenario	Sin roles	Con roles (RBAC)
Las personas cambian de puesto frecuentemente	Requiere un esfuerzo enorme ir siempre revocando y concediendo permisos sobre la marcha uno por uno por cada usuario, el humano al final del día se equivoca y hay un mayor margen de errores.	El usuario nunca posee los permisos, los obtiene a través de los roles, con simplemente cambiar el rol del usuario cambian todos sus permisos.
Gestión de una base de datos y auditoría	Difícil de auditar y es probable que se produzcan inconsistencias de datos.	Todo esta centralizado, es más facil auditar y mantener.
Seguridad de datos (acceso, modificación, borrado, etc)	Riesgo alto de excesos de privilegios en usuarios o incluso que se olvide revocar los permisos de los mismos.	Al no tener que elegir manualmente los permisos porque vienen definidos por los roles hay menor probabilidad de una asignación equivocada de roles.

Política de acceso basada en sucursales y/o horarios

Como **RBAC** es muy rígido no es ideal para implementar controles de permisos y accesos basados en elementos demasiado variables o cambiantes, precisamente, por ejemplo la **hora** o si se encuentra en una sucursal u otra son ese tipo de elementos, por lo tanto, la mejor opción sería **ABAC** que nos permitirá definir reglas como por ejemplo “Solo dar permisos/acceso si X usuario se encuentra en X sucursal y la hora actual se encuentra entre X valor y X valor”.